



passwords, insecure implementation of data transfer or data storage, exploitable factory settings, etc put these devices in a high-risk situation.

THE ATTACKS:

Let's take a look into some of the biggest IoT attacks that have ever taken place:

- **The Mirai Botnet:** This will always take the first place when talking about IoT attacks or cyber-attacks in general. The attack took place in October 2016 and to this day, it is the largest DDoS (Distributed Denial of Service) attack that has ever been performed. The attack on Dyn, a DNS service provider,



Security? Perhaps, not.

was so devastating that even online giants like Reddit, Twitter, CNN, Netflix, etc were affected. The attack is named after the Mirai malware, which targeted IoT devices which had their IP listed publicly on the internet. Once a device was infected, it continuously scanned the internet for other IoT devices and then leveraging the weak password implementation, brute-forced the login using more than 60 factory default username and password combinations. After successfully logging in, the process was repeated and the number of infectious devices increased exponentially. This proves how crucial it is to have strong credentials and periodic firmware updates.

- **Hackable Cardiac Devices:** In 2017, the FDA declared that a serious vulnerability had been found in the pacemakers made by St. Jude Medical, resulting in FDA recalling around 500,000 pacemakers already in circulation. The vulnerability was present in how the pacemaker communicated with external programs and services. A hacker could use commer-

cially available equipment to access the device and reprogram the device. For example, the battery can be made to drain out quickly or worse, the pace can be altered, both resulting in the death of the user of the device.

- **Owlet Wi-Fi Baby Heart Rate Monitor:** In 2016, a security researcher bought Owlet's heart rate monitor for his infant but soon found how vulnerable the device was. The base Wi-Fi station that the device used to communicate data with the sensor was completely unauthenticated and access to someone else's baby monitor was as simple as scanning the relevant port and browsing to that IP. This allowed snooping on details and even silencing of important alerts.

- **The TRENDnet Webcam Hack:** When the SecurView webcams were introduced in the market, TRENDnet showcased them as cameras with multiple uses, including as baby monitors. They were meant to be secure too, as the name alludes to. But allusions were all that was provided. Because as it was revealed later, anyone with the public IPs of these cameras could access the video interface and in some cases, even audio recording was possible! FTC later revealed that the user information was being transmitted by TRENDnet over the internet without encryption. It was in plain text, readable by anyone.

- **The JEEP Hack:** Long before Tesla was hacked, two security researchers, Charlie Milner and Chris Valasek, were able to break into the onboard software of the Jeep Cherokee and had complete control of the automobile. Each system on the Cherokee model vehicle had a CAN bus – it's like the guy who controls everything. The researchers were able to compromise a functionality, which even though didn't communicate with the CAN bus directly, was a controller which was connected to the CAN bus, simply put they were able to access the CAN bus by proxy. There was no access authorisation implemented on the controller's firmware update and as a result, they were able to alter every configuration that was available in the car! They

were in control of the speed, the steering wheel, the brake, the music system and whatever other feature the car provided.

THE DEFENCE:

After putting into perspective how big the risks and dangers are, it's time to get technical. Since time immemorial, it's been said that offence is the best defence and the same goes for security. Offensive security, where you try to break things before patching them up, helps more by giving insights and covering all the grounds. So how do you approach an IoT device from an offensive security point of view?

- **Analysis:** Gathering all the information about the firmware of the device you are trying to break is crucial. Then only you can move forward with vulnerability assessment and exploit development. You can proceed with analysis with either analysis frameworks or independent analysis tools. Frameworks provide a complete set of tools for intense analysis and extraction of important information from the image files of the firmware. One immensely popular framework is Exploit, which is like Metasploit but for IoT devices. It is a tool written in python which allows security testing and exploitation of IoT devices and IoT infrastructure. Then there is the Firmware Analysis and Comparison Tool (FACT) which is a full-fledged framework which analyses, extracts and compares different versions of the firmware. It also analyses the plug-ins installed, if any, on the firmware. Other than firmware analysis, if the IoT device has a web application frontend or a mobile application, those things can be probed too to get valuable information. For example, many routers have web login pages, sometimes with default passwords and a lot of smart home devices come accompanied by a mobile application that can be pentested.

- **Reverse Engineering:** After automated analysis, it's time to jump into the ocean of assembly language. Reverse engineering is important to understand how the product actually works. There are two kinds of reverse